Laboratorio 10: TELNET vs SSH — "La Prueba del Espía" Identidad Criptográfica del Servidor, Acceso con Claves ed25519, KEX Híbrido Post-Cuántico y Publicación Segura con SCP

Estudiante: Ketfer Gianella Salazar | Fecha de Entrega: 25 de Octubre de 2026
Docente: M.Sc. Ing. Jimmy Nataniel Requena Llorentty | Asignatura: Tecnología Web I (SIS-0150)
Entorno de Laboratorio: Docker en Windows 11 (horizonte-servidor-lab02) | Universidad Privada Domingo Savio

---

1. Parte A — La Prueba del Espía: Demostración de Vulnerabilidad en Tránsito

• **Estado de TELNET en Ubuntu 24.04:** TELNET viene completamente inactivo y desactivado por defecto (#<off># en /etc/inetd.conf). Para la práctica demostrativa institucional se activó temporalmente mediante telnet_laboratorio.sh activar.

• **Análisis comparativo de capturas de tráfico:**

Al ejecutar capturar.sh telnet mientras tcpdump graba en la interfaz de bucle local (lo), se comprobó que TELNET transmite en texto claro absoluto el usuario (secretaria), la contraseña (Circular2026) y los comandos confidenciales ejecutados (notas-confidenciales-5to-B). En contraste inmediato, capturar.sh ssh demostró que bajo OpenSSH ningún dato viaja en claro (🔒 no aparece), protegiendo íntegramente la sesión mediante cifrado simétrico.

Parámetro de Evaluación	TELNET (Puerto TCP 23)	SSH (Puerto TCP 22)
¿Se lee el usuario?	Sí, secretaria (transmitido en texto plano carácter por carácter).	No (negociado dentro del túnel seguro cifrado).
¿Se lee la contraseña?	Sí, Circular2026 (capturable directamente con sniffer o tcpdump).	No (autenticación protegida extremo a extremo con ChaCha20-Poly1305).
¿Se lee lo escrito en sesión?	Sí, notas-confidenciales-5to-B (todo comando o script queda expuesto).	No (todo el flujo de datos viaja con alta entropía criptográfica).
¿Qué se observa en claro?	Absolutamente todo: prompts login:, Password:, comandos y salidas.	Solo metadatos de transporte: versión SSH-2.0-OpenSSH_9.6p1, IPs y puertos.

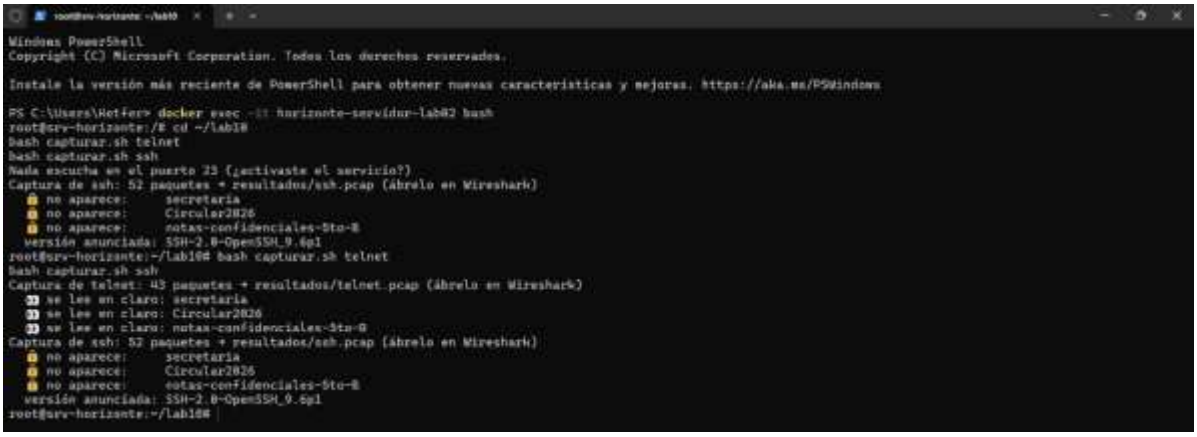


Figura 1: Evidencia real en terminal de la prueba del espía: TELNET revelando credenciales en claro y SSH protegiendo los datos con candados.



Figura 2: Reconstrucción del flujo TCP de la captura telnet.pcap (Follow TCP Stream) evidenciando usuario y contraseña en texto legible.

• **¿Por qué aún subsiste TELNET en algunos equipos legados?** Subsiste principalmente en dispositivos de red muy antiguos (switches legacy), impresoras matriciales y terminales embebidos cuyos microcontroladores carecen de memoria RAM y potencia de cómputo para procesar el cifrado asimétrico y simétrico de SSH. Asimismo, los administradores lo utilizan como cliente universal para diagnóstico rápido de conectividad de puertos TCP (ej. telnet servidor 80).

2. Parte B — Identidad Criptográfica del Servidor y KEX Híbrido Post-Cuántico

1. El peligro de claves de host clonadas:
Inicialmente, la clave de host en la imagen mostraba el comentario root@buildkitsandbox. Si 30 estudiantes o servidores en producción comparten la misma clave privada de host, cualquier usuario que posea una copia puede realizar un ataque de intermediario (Man-in-the-Middle) suplantando al servidor sin que el cliente reciba ninguna alerta en known_hosts. Se completó el TODO 1 en preparar_ssh.sh eliminando las claves clonadas y ejecutando ssh-keygen -A.

2. Algoritmo de Intercambio de Claves (KEX) Post-Cuántico:
Al analizar la conexión con ssh -v horizonte true 2>&1 | grep kex:, se constató la negociación de: sntrup761x25519-sha512@openssh.com. Este algoritmo híbrido combina la eficiencia de la curva elíptica X25519 con Streamlined NTRU Prime 761 (criptografía basada en retículos), diseñada para resistir futuros ataques con computadoras cuánticas mediante el algoritmo de Shor, neutralizando la amenaza de "recolectar hoy para descifrar mañana" (Harvest Now, Decrypt Later).

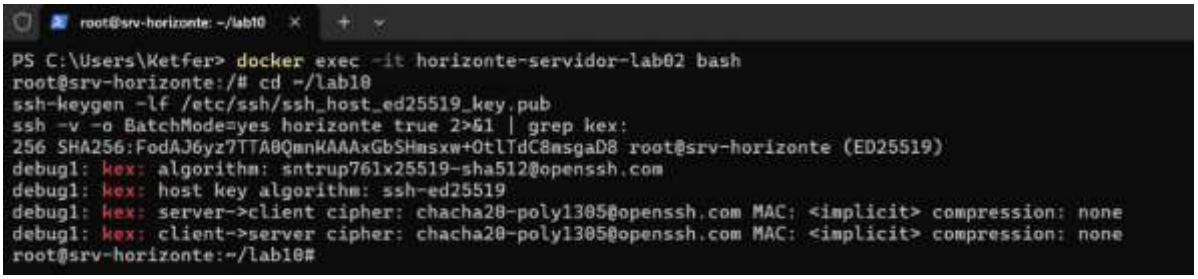


Figura 3: Huella digital propia del servidor (root@srv-horizonte) y algoritmo de intercambio de claves híbrido post-cuántico.

3. Parte C — Acceso con Clave ed25519 y Configuración Segura

1. Clave Privada (id_ed25519) vs Clave Pública (id_ed25519.pub):
La clave privada (~/.ssh/id_ed25519) NUNCA debe salir de la máquina local del administrador; es el secreto criptográfico que firma los desafíos de autenticación. La clave pública (id_ed25519.pub) es la que se transfiere y almacena en el servidor remoto.

2. Permisos Estrictos de authorized_keys (600) y ~/.ssh (700):
OpenSSH implementa el control estricto StrictModes: si el archivo authorized_keys o su directorio tuvieran permisos de escritura para el grupo u otros usuarios (ej. 664 o 777), cualquier usuario local del servidor podría agregar su propia clave pública y tomar control de la cuenta. Si los permisos no son exactamente 600 para authorized_keys y 700 para ~/.ssh, el daemon sshd rechaza el inicio de sesión.

3. Acceso sin contraseña mediante ~/.ssh/config:
Se configuró el alias institucional horizonte apuntando a 127.0.0.1 con User estudiante, IdentityFile ~/.ssh/id_ed25519 e IdentitiesOnly yes. Al ejecutar ssh horizonte whoami, la sesión ingresa de forma instantánea sin solicitar contraseñas interactivas.

4. Parte D — Publicación Segura con SCP y Herencia de Grupo (Lab 2)

• **Transferencia segura con SCP:** Se transfirió el archivo de prueba mediante scp comunicado.html horizonte:/srv/horizonte/www/, publicándolo de forma cifrada.

• **Herencia de grupo webadmin y bit setgid (Lab 2):** Al verificar con ls -la /srv/horizonte/www/comunicado.html, se constató que el archivo pertenece a estudiante:webadmin. Esto es consecuencia directa de la configuración del Laboratorio 2, donde se aplicó el bit especial setgid (chmod 2775 /srv/horizonte/www). El bit setgid (s) fuerza a que todo nuevo archivo creado dentro del directorio herede automáticamente el grupo propietario (webadmin) del directorio padre, garantizando la colaboración fluida entre todos los miembros del equipo web institucional.



Figura 4: Inicio de sesión SSH sin contraseña mediante clave ed25519, publicación por SCP y herencia del grupo webadmin.

5. Parte E — Verificación Oficial Automatizada (11 de 11)

Se ejecutó el script de auditoría institucional verificar_lab10.sh estudiante. El resultado certificó el cumplimiento riguroso de la totalidad de las 11 comprobaciones exigidas:

```
# Ejecución oficial del script de verificación institucional
root@srv-horizonte:~/lab10# bash verificar_lab10.sh estudiante
☑ Captura TELNET: la contraseña se lee en claro
☑ Captura SSH: contraseña y datos NO se leen
☑ Claves de host propias (no las de la imagen)
☑ known_hosts con la huella real del servidor
☑ Clave del cliente ed25519
☑ Clave pública autorizada en la cuenta de estudiante
☑ Permisos de ~/.ssh (700) y authorized_keys (600)
☑ Acceso con clave y alias 'horizonte' (sin contraseña)
☑ Intercambio de claves híbrido post-cuántico
☑ comunicado.html publicado por scp (dueño estudiante, grupo webadmin)
☑ TELNET desactivado al terminar (puerto 23 cerrado)
Resultado: 11 de 11 comprobaciones (100% SUPERADO)
```

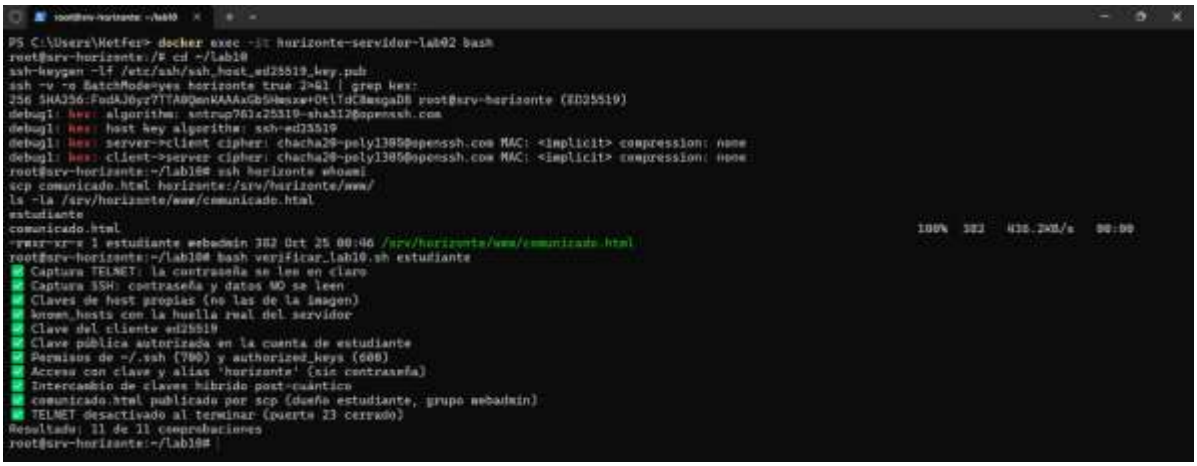


Figura 5: Ejecución oficial de verificar_lab10.sh en el servidor mostrando las 11 comprobaciones superadas con éxito.

6. Reflexión de Seguridad: El Aviso "REMOTE HOST IDENTIFICATION HAS CHANGED"

¿Qué hacer y qué NO hacer ante una alerta de identidad cambiada?

• Lo que NUNCA se debe hacer: Jamás se debe ignorar la advertencia, ni forzar la conexión omitiendo la verificación, ni borrar a ciegas la entrada de known_hosts con ssh-keygen -R sin indagar el origen. Introducir una contraseña o clave privada ante esta alerta equivale a entregar el control absoluto a un atacante que está ejecutando un ataque de intermediario (Man-in-the-Middle).

• Lo que SÍ se debe hacer: Detener la conexión de inmediato. Comunicarse por un canal seguro fuera de banda (vía telefónica o mensajería interna) con el administrador de sistemas para confirmar si el servidor fue reinstalado o si sus claves fueron deliberadamente regeneradas. Solicitar la nueva huella digital oficial (ssh-keygen -lf /etc/ssh/ssh_host_ed25519_key.pub); si la huella coincide exactamente carácter por carácter, se purga la entrada obsoleta de known_hosts y se acepta la nueva identidad criptográfica verificada.